

AI Governance Policy

FortisAid Health Technologies

Policy Number: FTAID-POL-005

Version 1.0 | Effective: 20 Feb 2026

Document Control Page

Field	Details
Policy Title	AI Governance Policy
Policy Number	FTAID-POL-005
Author	Head of Governance Risk and Compliance
Policy Owner	Chief Information Security Officer
Reviewer	Data Protection Officer
Approver	Chief Executive Officer
Version	1.0
Effective Date	20 February 2026
Current Review Date	20 February 2026
Next Review Date	20 February 2027
ISO 27002:2022 Primary Domain	Organisational Controls
ISO 27002:2022 Primary Sub-domain	Threat intelligence
ISO 27002:2022 Primary Control	5.7 – Threat intelligence
Related Policies	Data Protection Policy, Third-Party Security Policy, Privileged Account Policy

1. Purpose and Scope

Purpose:

To establish governance for AI/ML systems used in clinical data analytics, remote patient monitoring (RPM) predictions, and decision support, ensuring patient safety, data privacy, and regulatory compliance.

Scope:

All AI/ML models, algorithms, and tools processing PHI/PII within FortisAid's cloud platforms, EHR integrations, and RPM services.

FortisAid Context:

Governs AI analytics on EHR, diagnostic images, lab results, and RPM data streams for healthcare providers.

2. ISO 27002:2022 Multi-Domain Alignment

ISO Domain	ISO Sub-domain	Control	Policy Coverage
Organisational (Primary)	Threat intelligence	5.7	AI threat intel, model risk assessment
Organisational	Privacy/PII	5.34	PHI protection in AI training/processing
Organisational	Supplier relationships	5.23	Cloud AI services (AWS SageMaker, Azure ML)
Technological	Monitoring activities	8.16	AI model performance monitoring
People	Awareness/training	6.3	AI ethics/responsible use training

3. Policy Statements / Requirements

3.1 AI Inventory and Classification

- Maintain **central AI inventory** documenting all models (RPM predictions, diagnostic analytics, triage tools) with data sources, PHI classification, and risk rating (Low/Medium/High).
- **High-risk AI** (direct clinical impact: dosing, triage) requires CISO + Clinical Systems Director approval.
- All AI processing **special category data** (health) triggers mandatory DPIA per UK GDPR Article 35.

3.2 Threat Intelligence and Model Risk Assessment

- Leverage **AI-specific threat intelligence** (5.7) for healthcare/cloud risks: bias, poisoning, inversion attacks.
- Conduct **pre-deployment risk assessment** evaluating data quality, model robustness, bias testing, adversarial robustness.
- **Vendor AI services** (AWS SageMaker, Azure ML) assessed per 5.23 cloud security requirements.

3.3 Data Governance and Privacy (5.34)

- **PHI minimization:** Use pseudonymized/synthetic data for training where possible; raw PHI only with explicit consent.
- Implement **differential privacy** or federated learning for RPM data to prevent re-identification.
- **Model cards** documenting training data demographics, bias metrics, performance on subgroups published internally.

3.4 Monitoring and Human Oversight (8.16)

- Deploy **model monitoring** tracking drift, performance degradation, bias drift on production RPM/clinical data.
- **Human-in-the-loop** required for high-risk decisions (triage, dosing recommendations).
- **Incident reporting:** AI errors/bias incidents reported per Incident Management Policy within 24 hours.

5. Roles and Responsibilities

Role	Responsibilities
Chief Executive Officer	Approves high-risk AI deployments
Chief Information Security Officer	Policy owner, chairs AI Governance Committee
Head of Governance Risk & Compliance (Author)	AI inventory, risk assessments, DPIAs
Data Protection Officer (Reviewer)	PHI compliance, bias audits
Clinical Systems Director	Validates clinical AI accuracy/safety
Security Engineering Lead	Model monitoring, threat intel integration

6. Compliance and Enforcement

Monitoring Activities:

Activity	Frequency	Responsible	Evidence
AI inventory update	Monthly	Head GRC	AI register
Model monitoring alerts	Continuous	Sec Engineering	Monitoring dashboard
Bias/performance audit	Quarterly	DPO	Audit reports
Governance Committee	Quarterly	CISO	Meeting minutes
High-risk review	Annual	CEO	Approval records

Non-Compliance: Unauthorized AI deployment triggers immediate suspension and disciplinary review.

7. Training and Awareness

- **Mandatory completion** of AI Governance policy-specific training within **30 days of joining**.
- **Annual refresher training** for all staff interacting with AI systems (developers, data scientists, clinicians).
- **Role-specific training** for privileged roles (AI model admins) and clinical staff using AI outputs: Algorithmic bias recognition and reporting , Human-in-the-loop decision protocols, PHI handling in AI training pipelines and Incident reporting for AI errors/malfunctions

Training Delivery: Delivered via Wizer platform with acknowledgment required before system access granted.

8. Review and Revision

- This policy will be reviewed **annually** or following **significant incidents** (AI bias events, model failures, regulatory changes).
- **Next scheduled review: 20 February 2027.**
- **Triggers for unscheduled review:** MHRA AI guidance updates, new GDPR enforcement, major AI incidents.